Incident Response Playbook

This playbook documents the standard response process that should be followed when dealing with a brute force attack on a system. I have learned this process by detecting and analyzing such attacks in the SOC Home Lab Project 1 environment. The process will enable a SOC analyst to respond to such an attack in a structured manner throughout the incident lifecycle.

1. Detection

Wazuh's correlation engine detects repeated failed login attempts (Event ID 4625) and escalates from individual low-severity alerts (Rule 60122, Level 5) to a high-severity correlated alert (Rule 60204, Level 10 — Multiple Windows Logon Failures) once a volume threshold is crossed within a short time window.

2. Initial Triage

Upon receiving the Level 10 alert, the analyst checks: source IP address, number of failed attempts, which accounts were targeted, and whether the source is internal or external.

3. Investigation

Source IP is checked against AbuseIPDB and GreyNoise for known malicious activity. Logs are searched for the keyword "Accepted" or successful logon events from the same source IP to confirm whether any attempt succeeded. If multiple machines show alerts from the same IP, this indicates broader targeting and raises priority.

4. Containment

If the IP is external and confirmed malicious, it is blocked at the firewall. Targeted accounts are temporarily locked or forced to reset passwords. If internal, the source machine is isolated from the network pending investigation.

5. Eradication

If any login succeeded, the analyst checks for created accounts, scheduled tasks, or new services indicating persistence. Any unauthorized changes are reverted.

6. Recovery

Affected accounts are monitored for 24-48 hours. Source IP block remains in place. Systems are confirmed clean before returning to normal monitoring.

7. Lessons Learned

Ticket is documented with full timeline, IOCs, and actions taken. If repeated brute force attempts are common, recommend implementing account lockout policies and rate limiting.